eURC

eURC Point of Sale (React + Node.js) · Hands-on Project 02 · Azure infrastructure architecture

Three isolated environments on Azure

Sheet 1 · resource groups, network, identity flows

Delivery · GitHub

2 developers + 1 tester → PR → repo **eurc-platform** branch: main → GitHub Actions

Workflows
ci.yml — every pull request
cd.yml — every merge to main
rollback.yml — manual, needs approval

GitHub environments (deploy from main only)

- dev — automatic
- test — automatic after dev
- prod — QA sign-off by the tester

Variables only (tenant, subscription and client IDs, resource-group names, alert e-mail). **No secrets**: Azure login is OpenID Connect.

Protect-main ruleset: pull request + green checks *app* · *infra* · *scripts*; no force-push, no delete.

OIDC ⑤

Microsoft Entra ID (tenant)

Workload identity federation: the job's GitHub token (sub = *repo:<owner>/eurc-platform:environment:<env>*) is exchanged for an Entra access token of that environment's identity.

⑤ deploy

rg-eurc-cicd-cc · deployment identities

id-eurc-gh-dev-cc · id-eurc-gh-test-cc · id-eurc-gh-prod-cc

Each identity: **Contributor** on its own resource group only + **RBAC Administrator constrained** to assigning Key Vault Secrets Officer / Storage Blob Data Contributor to managed identities. The dev pipeline cannot touch prod.

Legend

- user traffic (HTTPS, TLS 1.2+)
- private / identity-based access
- telemetry and diagnostic logs
- pipeline deployment (ARM, OIDC)

① users → web app ② app → data via managed identity
③ prod: VNet integration → private endpoints
④ telemetry → App Insights / Log Analytics ⑤ deploy

Azure for Students subscription

Region: Canada Central (canadacentral)

① **Tenant users (Internet)** → https://app-eurc-web-<env>-cc-<sfx>.azurewebsites.net

rg-eurc-dev-cc

- asp-eurc-dev-cc-001 — **Linux B1**
- app-eurc-web-dev-cc-<sfx> — POS: React + Node 22 API
- id-eurc-app-dev-cc — app runtime identity
- token
- ② Data tier — Entra ID auth only
- kv-eurc-dev-cc-<sfx> — RBAC · signing key
- steurcdevcc<sfx> — LRS · receipts
- sql-eurc-dev-cc-<sfx> — sqldb-eurc-core-dev · Basic
- telemetry
- log-eurc-dev-cc-001
- appi-eurc-dev-cc-001 ④

Every merge to **main** lands here first.
Gate: smoke suite (8 checks).
Public endpoints; SQL firewall = Azure services only; storage shared keys off.

rg-eurc-test-cc

- asp-eurc-test-cc-001 — **Linux B1**
- app-eurc-web-test-cc-<sfx> — POS: React + Node 22 API
- id-eurc-app-test-cc — app runtime identity
- token
- Data tier — Entra ID auth only
- kv-eurc-test-cc-<sfx> — RBAC · signing key
- steurctestcc<sfx> — LRS · receipts
- sql-eurc-test-cc-<sfx> — sqldb-eurc-core-test · Basic
- telemetry
- log-eurc-test-cc-001
- appi-eurc-test-cc-001

Auto-promoted after dev passes.
Gates: smoke · integration (store trading day across SQL, Blob, Key Vault) · load (p95 < 1.5 s) · Playwright E2E.
Tester signs off here.

rg-eurc-prod-cc

- asp-eurc-prod-cc-001 — **Linux S1**
- app-eurc-web-prod-cc-<sfx> — **production slot**
- swap (warm-up /health)
- ...-prod-cc-<sfx>-staging — **staging slot**
- id-eurc-app-prod-cc — shared by both slots
- VNet integration ③
- vnet-eurc-prod-cc-001 · 10.20.0.0/16
  - snet-eurc-appint-prod-cc — 10.20.1.0/24 · delegated to Microsoft.Web — NSG nsg-snet-eurc-appint-prod-cc
  - snet-eurc-pe-prod-cc — 10.20.2.0/24 · NSG allows 443/1433 from appint only
    - pe-eurc-sql-prod-cc
    - pe-eurc-blob-prod-cc
    - pe-eurc-kv-prod-cc
  - Private DNS zones (linked) ④
    - privatelink.database.windows.net
    - privatelink.blob.core.windows.net
    - privatelink.vaultcore.azure.net
- Data tier
  - sql-eurc-prod-cc-<sfx> — Basic · Entra only
  - steurcprodcc<sfx> — ZRS · no shared keys
  - kv-eurc-prod-cc-<sfx> — RBAC

Public network access: Disabled on SQL, Storage and Key Vault (reachable only through the private endpoints)

Monitoring & alerting

- log-eurc-prod-cc-001 — 30 days · 1 GB/day cap
- appi-eurc-prod-cc-001 — OpenTelemetry
- webtest-eurc-health-prod — 3 locations · 10 min
- 6 metric alerts + slot-swap activity alert
- ag-eurc-ops-prod → e-mail

Diagnostic settings from web app, SQL database, Blob service and Key Vault → Log Analytics. The CD post-deployment gate queries **AppRequests** for the new version.

Production design
- S1 plan: required for the **staging slot**; deploy → test → swap = zero downtime, instant rollback
- One managed identity for both slots, so a swap never changes who talks to the data tier
- Only private (RFC 1918) traffic routes into the VNet; internet egress (Entra ID, App Insights) stays on App Service — no NAT gateway needed
- CanNotDelete locks on SQL, Storage, Key Vault (03-harden-prod.sh) · Storage ZRS · SQL backups 7 days

Project	Drawing	Sheet
eURC POS · P02	EURC-P02-AZR-01	1 of 2
Revision	**Standard**	**Format**
1.1 · 2026-10-23	Azure CAF naming	A3 landscape

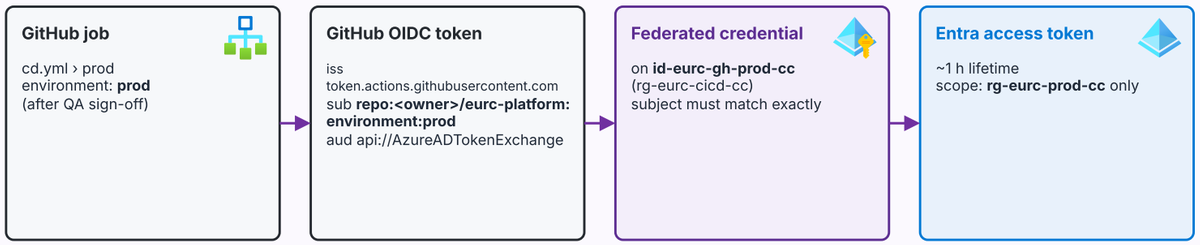
eURC

eURC Point of Sale (React + Node.js) · Hands-on Project 02 · Azure infrastructure architecture

Identity, security, monitoring and cost

Sheet 2 · who can do what, controls, alerts, budget

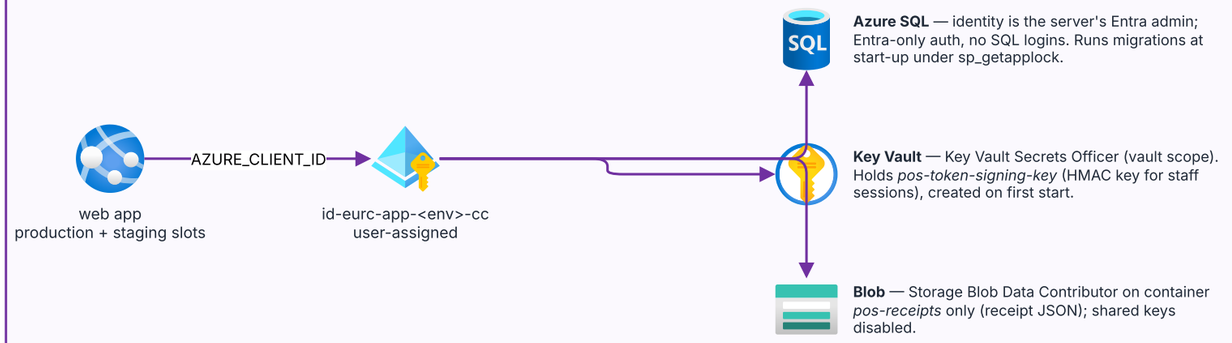
A · Pipeline identity: OpenID Connect, no secrets (example: prod)



Why one identity per environment? A token minted for a *dev* job can never act on prod: the subject includes the GitHub environment, and the prod environment only runs from *main* after a reviewer approves. Deleting a federated credential instantly cuts the pipeline off — there is no leaked secret to rotate.

Rights: **Contributor** on own resource group · **RBAC Administrator** with an ABAC condition: may assign only Key Vault Secrets Officer (b86a8fe4…) and Storage Blob Data Contributor (ba92f5b4…), only to service principals.

B · Application identity: managed identity to every data service



Lab trade-off: one identity both migrates and serves. In a real production system, split a migration identity (DDL) from the runtime identity (data read/write).

C · Access matrix (least privilege)

Principal	Scope	Role	Purpose
Lead (GITHUB_OWNER)	subscription · repo	Owner · admin	bootstrap, backup prod approver, teardown
Developers 1 + 2	repository	write (PR only)	branches, PRs, review each other
Tester	repo · env prod	write · required reviewer	owns tests/, QA sign-off
id-eurc-gh-dev-cc	rg-eurc-dev-cc	Contributor + RBAC Admin (conditioned)	dev deployments
id-eurc-gh-test-cc	rg-eurc-test-cc	Contributor + RBAC Admin (conditioned)	test deployments
id-eurc-gh-prod-cc	rg-eurc-prod-cc	Contributor + RBAC Admin (conditioned)	prod deployments (approved runs)
id-eurc-app-<env>-cc	SQL server (env)	Entra admin	migrations, stores, users, products, sales
id-eurc-app-<env>-cc	kv-eurc-<env>-cc-…	Key Vault Secrets Officer	session-signing key
id-eurc-app-<env>-cc	container pos-receipts	Storage Blob Data Contributor	receipts
Ruleset protect-main	branch main	PR + 1 review + code owners + 4 checks	no unreviewed change ships

D · Security controls by environment

Control	dev	test	prod
HTTPS only · TLS 1.2 min · FTP off · basic-auth publishing off	✓	✓	✓
Managed identity for SQL / Blob / Key Vault (no secrets in config)	✓	✓	✓
SQL Entra-only auth · Storage shared keys off · anonymous blob off	✓	✓	✓
Key Vault RBAC · soft delete 7 days	✓	✓	✓
Private endpoints + public network access disabled	–	–	✓
VNet integration · NSGs on both subnets	–	–	✓
CanNotDelete locks on data tier (03-harden-prod.sh)	–	–	✓
Deploy from main only · approval	main	main	QA sign-off
Conformance test: 20-test-env.sh (21 / 21 / 29 checks)	✓	✓	✓
App: scrypt passwords, signed sessions, roles, CSP, rate-limited sign-in, no card data	✓	✓	✓

E · Monitoring and alerts (prod)

Signal	Condition	Sev
alert-eurc-availability-prod	/health fails from ≥ 2 of 3 locations	0
alert-eurc-http5xx-prod	> 5 HTTP 5xx in 5 min	1
alert-eurc-healthcheck-prod	health check < 100 %	1
alert-eurc-latency-prod	avg response > 2 s	2
alert-eurc-plan-cpu-prod	plan CPU > 80 %	2
alert-eurc-sql-dtu-prod	SQL DTU > 80 %	2
alert-eurc-slot-swap-prod	any slot swap (release/rollback)	info
CD post-deploy gate	AppRequests failures < 2 % (new version)	gate

F · Cost estimate while running (USD, Canada Central)

Item	dev	test	prod	per day
App Service plan	B1	B1	S1	≈ 3.30
Azure SQL Basic (5 DTU)	1	1	1	≈ 0.50
Private endpoints + DNS zones	–	–	3 + 3	≈ 0.77
Availability test (432 runs)	–	–	1	≈ 0.22
Storage, Key Vault, logs	small	small	small	≈ 0.10
Total				**≈ 4.90**

Budget **budget-eurc-monthly** (USD 60): e-mails at 50 % / 80 % actual and 100 % forecast. Run **99-teardown.sh** when the lab is done.

G · Naming standard (Cloud Adoption Framework)

Pattern	Example (prod)
rg-eurc-<env>-cc	rg-eurc-prod-cc
app-eurc-web-<env>-cc-<sfx>	app-eurc-web-prod-cc-7k2qd
asp-eurc-<env>-cc-001	asp-eurc-prod-cc-001
sql-eurc-<env>-cc-<sfx> / sqldb-eurc-core-<env>	sql-eurc-prod-cc-7k2qd
steurc<env>cc<sfx> · kv-eurc-<env>-cc-<sfx>	steurcprodcc7k2qd
id-eurc-app-<env>-cc · id-eurc-gh-<env>-cc	id-eurc-gh-prod-cc
log- / appi-eurc-<env>-cc-001	appi-eurc-prod-cc-001

<sfx> = 5 characters of uniqueString(subscription, resource group): globally unique, stable on redeploy. Tags on everything: application, environment, costCenter, owner, managedBy, project.

Project	Drawing	Sheet
eURC POS · P02	EURC-P02-AZR-02	2 of 2
Revision	Standard	Format
1.1 · 2026-10-23	Azure CAF naming	A3 landscape